

Web Application Penetration Testing Checklist

A Structured Reference Checklist for Consistent, Repeatable Web Application Security Assessments

Prepared by: Nahla
Student ID: 24niZSZPvqYEcB53AUYPe2z4w9X2
Exercise: Concepts Exercise - Web Application Vulnerability Checklist
Document type: Penetration Testing Checklist (Reusable Reference Tool)
Vulnerabilities covered: 63 unique items across 13 categories
Reference framework: OWASP Top 10 (2021), OWASP Web Security Testing Guide (WSTG)

How to use this checklist

1. Work through the 'Checklist' sheet one category at a time, using the suggested tools as a starting point.
2. Toggle the 'Tested' tickbox once you have attempted a given check (click the cell and choose the checked option from the dropdown).
3. Set 'Test Performed' to Yes / No / N/A to track whether the check was actually executed against the target.
4. Record the outcome in 'Result' (Pass = not exploitable, Fail = vulnerable, Partial = partially exploitable / needs follow-up, N/A = out of scope).
5. Use 'Remarks / Observations' to capture evidence references, payloads used, screenshots filenames, or follow-up actions.
6. Check the 'Dashboard' sheet for a live summary of testing progress and results per category.
7. Add rows if a target requires additional checks; keep the ID scheme (CAT-##) consistent so filters keep working.

Legend

☐ / ☒	Not yet tested / Tested (tickbox)
Result: Pass	Application is not vulnerable to this check
Result: Fail	Application is vulnerable - finding to be reported
Result: Partial	Partially exploitable, inconclusive, or needs deeper testing
Result: N/A	Check does not apply to this target's technology stack

Cat. ID	Category	Vuln. ID	Vulnerability	Suggested Tools	OWASP / Reference	Tested	Test Performed	Result	Remarks / Observations
INJ	Injection Attacks	INJ-01	SQL Injection - Error-Based	sqlmap; Burp Suite; manual payload testing	A03:2021-Injection	☐	No	Not Tested	
INJ	Injection Attacks	INJ-02	SQL Injection - Blind (Boolean-Based)	sqlmap; Burp Suite Intruder	A03:2021-Injection	☐	No	Not Tested	
INJ	Injection Attacks	INJ-03	SQL Injection - Blind (Time-Based)	sqlmap; Burp Suite Intruder	A03:2021-Injection	☐	No	Not Tested	
INJ	Injection Attacks	INJ-04	NoSQL Injection	NoSQLMap; Burp Suite; manual payload testing	A03:2021-Injection	☐	No	Not Tested	
INJ	Injection Attacks	INJ-05	OS Command Injection	Commix; Burp Suite; manual payload testing	A03:2021-Injection	☐	No	Not Tested	
INJ	Injection Attacks	INJ-06	LDAP Injection	Burp Suite; manual payload testing	A03:2021-Injection	☐	No	Not Tested	
INJ	Injection Attacks	INJ-07	XML External Entity (XXE) Injection	Burp Suite; XXEinjector	A05:2021-Security Misconfiguration	☐	No	Not Tested	
INJ	Injection Attacks	INJ-08	Server-Side Template Injection (SSTI)	tplmap; Burp Suite	A03:2021-Injection	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-01	Weak Password Policy	Manual review; Burp Suite	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-02	Brute Force / Missing Account Lockout	Hydra; Burp Suite Intruder	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-03	Default or Weak Credentials	Manual testing; Nmap NSE scripts	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-04	Session Fixation	Burp Suite; manual testing	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-05	Insecure / Predictable Session Token	Burp Suite Sequencer	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-06	Session Timeout Not Enforced	Manual testing; Burp Suite	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-07	Missing Multi-Factor Authentication	Manual review	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-08	Password Reset Poisoning / Weak Reset Flow	Burp Suite; manual testing	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AUTH	Authentication & Session Management	AUTH-09	JWT Vulnerabilities (alg=none, weak secret)	jwt_tool; Burp Suite	A07:2021-Identification & Authentication Failures	☐	No	Not Tested	
AC	Access Control	AC-01	Insecure Direct Object Reference (IDOR)	Burp Suite; Autorize extension	A01:2021-Broken Access Control	☐	No	Not Tested	
AC	Access Control	AC-02	Broken Function-Level Authorization (Vertical Escalation)	Burp Suite; manual testing	A01:2021-Broken Access Control	☐	No	Not Tested	
AC	Access Control	AC-03	Horizontal Privilege Escalation	Burp Suite; Autorize extension	A01:2021-Broken Access Control	☐	No	Not Tested	
AC	Access Control	AC-04	Missing Access Control on Admin Interfaces	Manual testing; DirBuster	A01:2021-Broken Access Control	☐	No	Not Tested	
AC	Access Control	AC-05	Path / Directory Traversal	Burp Suite; DotDotPwn	A01:2021-Broken Access Control	☐	No	Not Tested	
AC	Access Control	AC-06	Forced Browsing to Hidden Resources	ffuf; gobuster; feroxbuster	A01:2021-Broken Access Control	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-01	Reflected Cross-Site Scripting	Burp Suite; XSSStrike	A03:2021-Injection	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-02	Stored Cross-Site Scripting	Burp Suite; XSSStrike	A03:2021-Injection	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-03	DOM-Based Cross-Site Scripting	Burp Suite DOM Invader	A03:2021-Injection	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-04	Clickjacking	Burp Suite; manual iframe PoC	A05:2021-Security Misconfiguration	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-05	Open Redirect	Burp Suite; manual testing	A01:2021-Broken Access Control	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-06	CORS Misconfiguration	Burp Suite; CORSScanner	A05:2021-Security Misconfiguration	☐	No	Not Tested	
XSS	Cross-Site Scripting & Client-Side	XSS-07	Cross-Site Script Inclusion (XSSI)	Burp Suite; manual testing	A03:2021-Injection	☐	No	Not Tested	
CSRF	Cross-Site Request Forgery	CSRF-01	Cross-Site Request Forgery on State-Changing Actions	Burp Suite; CSRF PoC generator	A01:2021-Broken Access Control	☐	No	Not Tested	
CSRF	Cross-Site Request Forgery	CSRF-02	Missing or Weak Anti-CSRF Tokens	Burp Suite	A01:2021-Broken Access Control	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-01	Directory Listing Enabled	Nikto; manual browsing	A05:2021-Security Misconfiguration	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-02	Verbose Error Messages / Stack Traces	Manual testing; Burp Suite	A05:2021-Security Misconfiguration	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-03	Unnecessary HTTP Methods Enabled (TRACE, PUT)	Nmap; curl; Burp Suite	A05:2021-Security Misconfiguration	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-04	Missing Security Headers (CSP, HSTS, X-Frame-Options)	Burp Suite; securityheaders.com	A05:2021-Security Misconfiguration	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-05	Outdated Software / Unpatched Components	Nikto; Nessus; WhatWeb	A06:2021-Vulnerable & Outdated Components	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-06	Default, Sample or Backup Files Exposed	ffuf; gobuster	A05:2021-Security Misconfiguration	☐	No	Not Tested	
CFG	Security Misconfiguration	CFG-07	Misconfigured Cloud Storage (S3 / Blob Buckets)	S3Scanner; manual testing	A05:2021-Security Misconfiguration	☐	No	Not Tested	
CRYPTO	Cryptography & Data Protection	CRYPTO-01	Sensitive Data Transmitted Over HTTP	Wireshark; Burp Suite	A02:2021-Cryptographic Failures	☐	No	Not Tested	
CRYPTO	Cryptography & Data Protection	CRYPTO-02	Weak SSL/TLS Configuration	testssl.sh; SSL Labs; sslscan	A02:2021-Cryptographic Failures	☐	No	Not Tested	
CRYPTO	Cryptography & Data Protection	CRYPTO-03	Sensitive Data Stored in Plaintext	Manual review; database inspection	A02:2021-Cryptographic Failures	☐	No	Not Tested	
CRYPTO	Cryptography & Data Protection	CRYPTO-04	Weak Password Hashing Algorithm	Manual review; Hashcat	A02:2021-Cryptographic Failures	☐	No	Not Tested	

Cat. ID	Category	Vuln. ID	Vulnerability	Suggested Tools	OWASP / Reference	Tested	Test Performed	Result	Remarks / Observations
CRYPTO	Cryptography & Data Protection	CRYPTO-05	Hardcoded Secrets / API Keys in Source Code	TruffleHog; manual code review	A02:2021-Cryptographic Failures	☐	No	Not Tested	
CRYPTO	Cryptography & Data Protection	CRYPTO-06	Insufficient Certificate Validation	Burp Suite; manual testing	A02:2021-Cryptographic Failures	☐	No	Not Tested	
FILE	File Handling & Upload	FILE-01	Unrestricted File Upload	Burp Suite; manual testing	A04:2021-Insecure Design	☐	No	Not Tested	
FILE	File Handling & Upload	FILE-02	Malicious File Execution After Upload	Burp Suite; manual testing	A04:2021-Insecure Design	☐	No	Not Tested	
FILE	File Handling & Upload	FILE-03	Local File Inclusion (LFI)	Burp Suite; ffuf	A03:2021-Injection	☐	No	Not Tested	
FILE	File Handling & Upload	FILE-04	Remote File Inclusion (RFI)	Burp Suite; manual testing	A03:2021-Injection	☐	No	Not Tested	
LOGIC	Business Logic	LOGIC-01	Race Conditions (TOCTOU)	Burp Suite Turbo Intruder	A04:2021-Insecure Design	☐	No	Not Tested	
LOGIC	Business Logic	LOGIC-02	Price / Quantity Manipulation	Burp Suite; manual testing	A04:2021-Insecure Design	☐	No	Not Tested	
LOGIC	Business Logic	LOGIC-03	Workflow / Sequence Bypass	Manual testing; Burp Suite	A04:2021-Insecure Design	☐	No	Not Tested	
LOGIC	Business Logic	LOGIC-04	Insufficient Anti-Automation Controls (no CAPTCHA)	Manual testing; Burp Suite	A04:2021-Insecure Design	☐	No	Not Tested	
API	API & Web Services	API-01	Missing Rate Limiting	Burp Suite Intruder	A04:2021-Insecure Design	☐	No	Not Tested	
API	API & Web Services	API-02	Mass Assignment	Burp Suite; manual testing	A08:2021-Software & Data Integrity Failures	☐	No	Not Tested	
API	API & Web Services	API-03	Excessive Data Exposure in API Responses	Burp Suite; Postman	A01:2021-Broken Access Control	☐	No	Not Tested	
API	API & Web Services	API-04	Broken Object Level Authorization (BOLA)	Burp Suite; Postman	A01:2021-Broken Access Control	☐	No	Not Tested	
API	API & Web Services	API-05	Improper Input Validation on Parameters	Burp Suite; Postman; ffuf	A03:2021-Injection	☐	No	Not Tested	
SSRF	Server-Side Request Forgery	SSRF-01	Server-Side Request Forgery	Burp Suite Collaborator	A10:2021-Server-Side Request Forgery	☐	No	Not Tested	
DOS	Denial of Service	DOS-01	Application-Layer Resource Exhaustion	Burp Suite; custom load scripts	A04:2021-Insecure Design	☐	No	Not Tested	
DOS	Denial of Service	DOS-02	Regular Expression Denial of Service (ReDoS)	Manual testing; regex analysis	A04:2021-Insecure Design	☐	No	Not Tested	
LOG	Logging & Monitoring	LOG-01	Insufficient Logging of Security Events	Manual review	A09:2021-Security Logging & Monitoring Failures	☐	No	Not Tested	
LOG	Logging & Monitoring	LOG-02	Log Injection	Burp Suite; manual testing	A09:2021-Security Logging & Monitoring Failures	☐	No	Not Tested	

Testing Progress Dashboard

Overall Summary

Total Vulnerabilities	63
Tested (ticked)	0
Not Tested	63
Result: Pass	0
Result: Fail	0
Result: Partial	0
Result: N/A	0

Breakdown by Category

Category ID	Total	Tested	Pass	Fail	Partial
INJ	8	0	0	0	0
AUTH	9	0	0	0	0
AC	6	0	0	0	0
XSS	7	0	0	0	0
CSRF	2	0	0	0	0
CFG	7	0	0	0	0
CRYPTO	6	0	0	0	0
FILE	4	0	0	0	0
LOGIC	4	0	0	0	0
API	5	0	0	0	0
SSRF	1	0	0	0	0
DOS	2	0	0	0	0
LOG	2	0	0	0	0